

STANSE: Bug-finding Framework for C Programs

Jan Obdržálek, Jiří Slabý and Marek Trtík

Masaryk University, Brno, Czech Republic
{obdrzalek,slaby,trtik}@fi.muni.cz

Abstract. STANSE is a free (available under the GPLv2 license) modular framework for finding bugs in C programs using static analysis. Its two main design goals are applicability on large software projects like the Linux kernel and extendability with new bug-finding techniques with a minimal effort. Currently there are three bug-finding algorithms implemented within STANSE: `AUTOMATONCHECKER` checks properties described in an automata-based formalism, `THREADCHECKER` detects deadlocks among multiple threads, and `REACHABILITYCHECKER` looks for unreachable code. STANSE has been tested on the Linux kernel, where it has found dozens of previously undiscovered bugs.

1 Introduction

During the last decade, bug-finding techniques based on static analysis have finally come of age. One of the papers to really stir interest was [1], showing that static analysis can efficiently find many interesting bugs in a real-world code. This work eventually led to a successful commercial tool called `COVERITY` [6]. Over the years, several other successful tools, like `CODESONAR` [5] or `KLOCWORK` [8], appeared. However, such fully-featured tools are neither free to obtain, nor is their code available (e.g. for developing new algorithms or tailoring the existing tools to specific tasks). The existing free tools are usually severely limited in what they can do (e.g. `UNO` [11], `SPARSE` [10], `SMATCH` [9]). One notable exception is `FINDBUGS` [3, 7], a successful tool working on Java code. STANSE is intended to fill this gap for C language. It can be seen in two ways:

1. STANSE is a robust framework (written predominantly in Java) for implementing diverse static analysis algorithms. An implemented algorithm can be immediately evaluated on large real-world software projects written in C as the framework is capable to process such projects (for example, it can process the whole Linux kernel). An implementation of such an algorithm within the framework is called *checker*.
2. As STANSE already contains three checkers, it can be also seen as a working static analysis tool.

The rest of the paper is structured as follows. Section 2 describes the functionality provided by the framework, while Section 3 is devoted to the three

existing checkers. Section 4 presents some results of STANSE on the Linux kernel. The last section summarizes the basic strengths of STANSE and mentions some directions of its future development.

2 Framework Functionality

STANSE framework is modular and fully open. It is designed to allow static analysis of large software projects (like Linux kernel), and to reduce an effort when implementing a new static analysis technique. Architecture of the framework is depicted in Figure 1. We describe its individual parts in separate subsections.

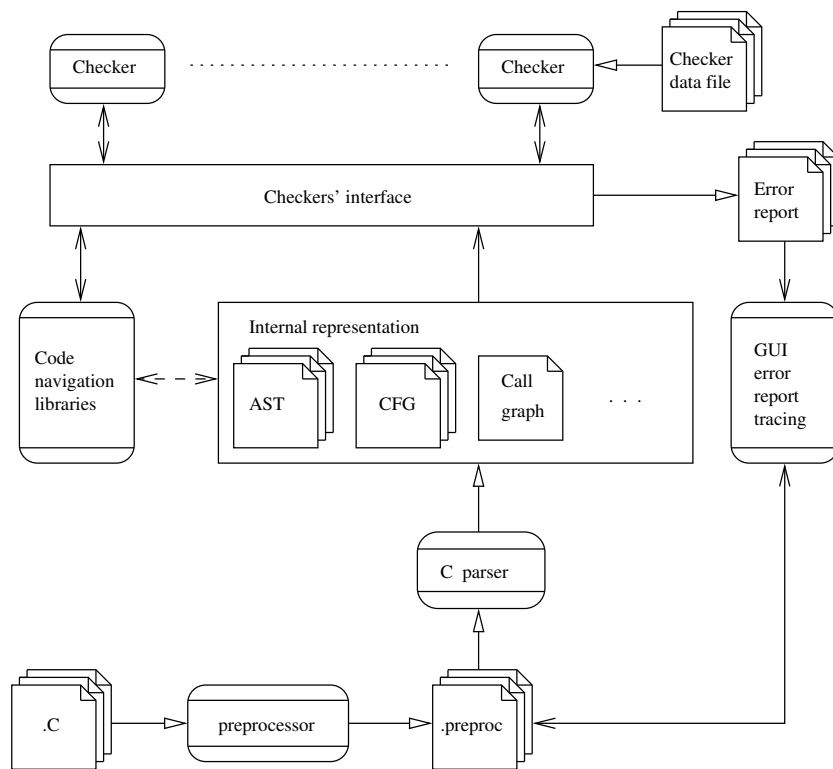


Fig. 1. STANSE framework architecture.

2.1 Configuration

STANSE framework contains data structures capturing a configuration of an analysis to be performed. We always need to know what source files to analyze and by what checkers. That information we call the *configuration*.

There are several ways how to tell STANSE what source files to analyse. Besides the standard possibilities (a single given file, all files from a given directory, all files listed in a given file), STANSE can also derive all the necessary information from a project `Makefile`. In this case, STANSE also remembers compiler flags for preprocessing purposes. This functionality is inspired by the `SPARSE` [10] tool. At bottom left corner of Figure 1 there we show a list of `.C` files which are identified in the configuration.

We also need to specify checkers which should be applied to chosen source files. We can see the list of selected checkers in the top of Figure 1. There can be many checkers running simultaneously in STANSE. But they do not see each other. They proceed independently. Checkers themselves might require their own configuration files. They are depicted at top right corner of Figure 1.

The configuration can be passed to STANSE framework via command line arguments or edited in GUI application.

2.2 Parsing Source Files

STANSE framework can process source files written in C. More specifically the ISO/ANSI C99 standard and most of the GNU C extensions. This allows STANSE to process software projects like Linux kernel. We are currently working on support of other languages, in particular C++. We have a prototype implementation, but it is not included in the distribution yet. The parsing pipeline, including a preprocessing the source files by the standard GNU C preprocessor, is depicted bottom in Figure 1. It is important to note that we do not parse all the sources in a sequence one by one as they appear in a configuration. Since we use streaming (discussed later), the pipeline is applied several times independently for individual source files.

2.3 Program Internal Representation

The code is then parsed into the *internal structures*: a call-graph, a CFG for each function, and an AST for the whole file. Subtrees in the AST are referenced from appropriate CFG nodes. We show these structures in the middle of Figure 1. All these structures can be dumped in a textual or graphical form.

Since we aim at large software projects consisting of hundreds or thousands of modules (compilation units), it is often impossible in practice to store the corresponding internal structures in the memory all at once. The STANSE framework therefore applies automatic *streaming* of the internal structures, currently on a module basis. Instead of parsing all source modules at the beginning, a module is streamed in only when STANSE needs to access some internal structure corresponding to the module. In other words, the internal structures are constructed in a lazy manner. If the memory occupied by internal structures exceeds a given limit, some internal structures have to be freed before another module is streamed in. The structures to be freed are selected by the LRU (least recently used) approach: STANSE discards all internal structures of the module

whose structures are not accessed for the longest time. If the discarded structure is later accessed again, the corresponding module is streamed back in. Both laziness of internal structures and streaming are completely invisible to checkers.

2.4 Traversing Internal Representation

Although a checker may need to work with the internal structures in an arbitrary way, most of checkers walk through CFGs using some standard strategy. To prevent unnecessary reimplementations, the most important and heavily used traversal methods are implemented directly inside the framework. With this functionality, one can implement a new checker (or its part) by specifying

- whether it should go through CFGs forwards or backwards, breadth-first or depth-first,
- if the interprocedural walk-through should be performed or not (if not, the function calls are ignored), and
- a method (callback) to be called for each visited node in a CFG.

This makes implementation of new algorithms extremely simple. The discussed functionality is shown to the left of internal representation in Figure 1.

2.5 Concept of Checkers

In STANSE framework a checker is an implementation of some concrete static analysis technique. Each checker has an access to shared internal structure of analysed source files. They are also gained an access to the algorithms providing navigation in those structures. This is done by an interface between checkers and internal structure and libraries of the framework. The interface is depicted in Figure 1 right bellow the checkers.

The checkers are integrated to the framework of STANSE using concrete factory design pattern. Therefore, to insert a new checker to the framework of STANSE one needs to implement general checker interface, and register it to the checkers' factory of the framework. Then it gains a full access to the features of the framework accessible through the discussed interface.

2.6 Processing Errors

Once a checker finds an error, it reports it back to the framework as a commented *error trace* (a path in the analysed code) demonstrating this error. STANSE framework provides a data type for describing an error. In the framework there are then several possibilities how to present the error traces back to the user of STANSE: they can be printed to the console, displayed using a built-in error trace browser in the GUI (see Figure 2), or saved to an external file in XML format. This XML file has a wide variety of possible applications. For example, we supply a tool transforming the XML file into an SQLITE database complemented with a web interface allowing to browse errors in the database via a web browser. Using

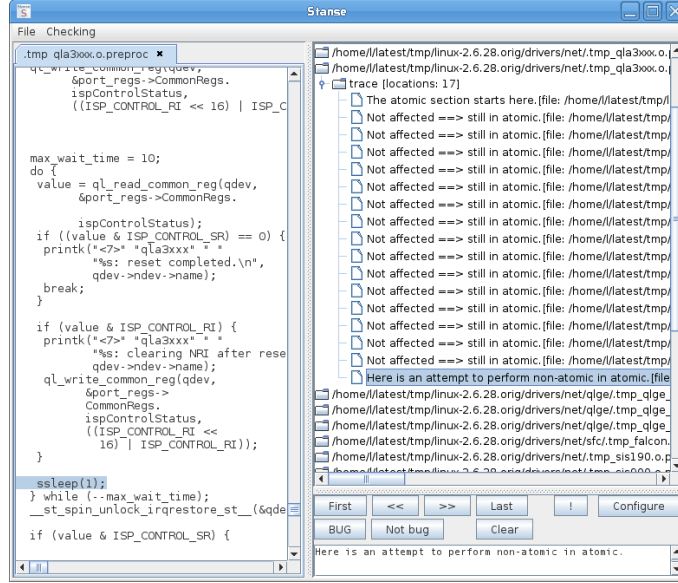


Fig. 2. Error trace browser in the STANSE GUI.

the web browser or the built-in graphical error browser, one can mark errors as real bugs or false positives. STANSE also provides various statistics of errors like number of errors per checker, frequency of errors of the same kind, percentage of false positives (based on user feedback).

Error reporting and tracing pipeline is depicted to the right of interface and internal representation of Figure 1.

3 Checkers

In this section we briefly describe the three currently available checkers.

AutomatonChecker is heavily influenced by [1]. It takes, as input, a set of finite-state automata that describe some properties which we want to check. Properties like locking discipline, interrupt management, null pointer dereference, dangling pointers and many others can be handled this way.

Compared to the implementation described in [1] and [2], our technique differs in several aspects. In particular, we do not use metacompilation, automata are not input-language specific (a pattern matching is used instead), and the interprocedural analysis is done in the context of a single input file.

ThreadChecker aims to check for possible deadlocks in concurrent programs. The technique is based on the notions of locksets of [4] and deadlock detection

by looking for cycles in *resource allocation graphs (RAGs)*. `THREADCHECKER` first tries to identify the parts of the code which can run in parallel, as different threads. Then it builds a set of *dependency graphs* for each such a thread. A dependency graph statically represents the possible locksets during one execution of a thread. Dependency graphs are then combined and transformed to RAGs. If some RAG contains a cycle, an error is reported.

ReachabilityChecker searches CFGs for unreachable nodes. These are then reported as warnings or errors, depending on importance (e.g. superfluous semicolons are less important than unused branch). The primary goal of `REACHABILITYCHECKER` is to demonstrate the simplicity of a new checker implementation using the framework features described in Subsection 2.4: the code of the checker has less than 200 lines including the mentioned error/warning classification and many strings and comments.

Checker	Automaton	Errors			Real/classified error ratio
		Found	Real	False pos.	
AUTOMATONCHECKER	Pairing	266	65	143	31.3 %
	Pointers	86	48	37	56.5 %
	Deadlocks	35	16	18	47.1 %
THREADCHECKER		20	9	11	45.0 %
REACHABILITYCHECKER		31	31	0	100.0 %
Overall		438	169	209	44.7 %

Table 1. STANSE results on the Linux kernel version 2.6.28.

4 Results on Linux Kernel

We have several reasons to choose the Linux kernel for testing STANSE: the kernel is a large and freely available codebase, it fully exercises most features of ISO/ANSI C99 and GNU C extensions, it is under constant development (there is a constant income of new bugs), and absence of bugs is of great concern.

We applied STANSE with the three checkers described in the previous section to version 2.6.28. `AUTOMATONCHECKER` uses three automata describing the following kinds of errors:

- incorrect pairing of functions (imbalanced locking, reference counting errors)
- bugs in pointer manipulation (null dereference, dangling pointers, etc.)
- deadlocks caused by sleeping inside spinlocks or interrupt handlers

The running time of STANSE on a common desktop machine with two 2.5 GHz cores and 4 GiB of memory is under two hours. The memory usage of the Java process oscillates between 400 and 1000 MiB. The number of errors found by

the checkers can be found in Table 1. Let us note that REACHABILITYCHECKER actually found 751 errors, but 720 of them are of low importance (including 696 superfluous semicolons) and they are omitted from our statistics.

We have manually analysed all the found errors and classified them as real errors or false positives (with an exception of 60 errors found by AUTOMATONCHECKER where we are not able to decide in a short time whether it is a false positive or not). The numbers of real errors, false positives and the ratio of real errors to all classified errors can be also found in Table 1. The overall ratio of real errors to all classified errors is not high: 44.7%. However, STANSE in the current version does not have any thorough false positive filtering technique.

More than 70 of the 169 real errors have been reported to kernel developers and fixed in the following kernel releases (the rest have been independently discovered and reported by someone else or the incorrect code disappeared from the kernel before we finished our evaluation of found errors). Some of the reported bugs remained undiscovered for more than seven years (for illustration, see our report at <http://lkml.org/lkml/2009/3/11/380>).

We have reported another 60 bugs found by STANSE in the subsequent versions of the kernel. This number is increasing every month.

5 Conclusions and Future Work

STANSE is a free Java-based framework for simple implementation of bug-finding algorithms based on static analysis. The framework can process large-scale software projects written in ISO/ANSI C99. STANSE does not currently use any new techniques – its novelty comes from the fact that (to our best knowledge) there is no other open-source framework with comparable applicability and efficiency. STANSE is available at <http://stanse.fi.muni.cz>. We note that more than 130 bugs found by STANSE have been reported to and confirmed by Linux kernel developers already.

Future Work We plan to improve the framework in several direction. We are currently working on C++ support. Further, we plan to provide STANSE in the form of a plug-in for Eclipse and NetBeans IDEs. A lot of work can be done in the area of automatic false alarm filtering and error importance classification. Independently of new features development, we would like to speed up the framework as well. More precisely, we intend to replace the current parser written in Java by an optimized parser written in C, to replace the XML format of internal structures by a more succinct representation, to add a support for function summaries, etc.

Acknowledgements Jan Kučera is the author of the THREADCHECKER. We would like to thank Linux kernel developers, and Cyrill Gorcunov for STANSE alpha testing and useful suggestions. All authors are supported by the research centre Institute for Theoretical Computer Science (ITI), project No. 1M0545.

References

1. D. Engler, B. Chelf, A. Chou, and S. Hallem. Checking system rules using system-specific, programmer-written compiler extensions. In *OSDI'00*, pages 1–16, 2000.
2. S. Hallem, B. Chelf, Y. Xie, and D. Engler. A system and language for building system-specific, static analyses. In *PLDI'02*, pages 69–82. ACM, 2002.
3. D. Hovemeyer and W. Pugh. Finding bugs is easy. In *OOPSLA'04*, pages 132–136. ACM, 2004.
4. J.W. Voung, R. Jhala, and S. Lerner. RELAY: static race detection on millions of lines of code. In *ESEC-FSE'07*, pages 205–214. ACM, 2007.
5. CODESONAR. <http://www.grammatech.com/products/codesonar/>.
6. COVERITY. <http://www.coverity.com/products/>.
7. FINDBUGS. <http://findbugs.sourceforge.net/>.
8. KLOCWORK. <http://www.klocwork.com/products/>.
9. SMATCH. <http://smatch.sourceforge.net/>.
10. SPARSE. <http://www.kernel.org/pub/software/devel/sparse/>.
11. UNO. <http://spinroot.com/uno/>.

A Availability

Website: <http://stanse.fi.muni.cz/>

Version: 1.0.0

Download: <http://stanse.fi.muni.cz/download>

The source code is also available. STANSE is distributed under the GPL v2 license. Currently, the tool is used mainly by the developers and students at the Masaryk University. It is also used by programmers in a partner software company, and a handful of Linux kernel developers. Several other kernel developers, in whose code STANSE has found bugs, have also expressed interest in using STANSE regularly¹. We therefore expect the number of users to go significantly up with the first full release 1.0.0.

¹ <http://lkml.org/lkml/2009/7/18/59> and follow-ups